

Simulating Credential Harvesting and Web Spoofing

Fady Youssef

Department of Computer Science
Gonzaga University
Spokane, USA
fyoussef@zagmail.gonzaga.edu

Steve Deibert

Department of Computer Science
Gonzaga University
Spokane, USA
sdeibert@zagmail.gonzaga.edu

William Wellborn

Department of Computer Science
Gonzaga University
Spokane, USA
wellborn@zagmail.gonzaga.edu

Keyu Chen

Department of Computer Science
Gonzaga University
Spokane, USA
kchen2@zagmail.gonzaga.edu

This project involved building a phishing simulation to demonstrate how easily students could be tricked by realistic looking attacks. We created a fake recovery page to mimic a typical Gonzaga University service and crafted a phishing email disguised as ITS to show how attackers might bait a victim. Although the email was never sent to students nor any of the information was stored, the simulation showed how phishing pages, work, what kind of information can be captured, and how attackers use it. The goal was to raise awareness about common yet effective phishing tactics and help Gonzaga students gain awareness of these red flags before it's too late.

Keywords—phishing attack, social engineering, simulation, web spoof, credentials harvesting, user awareness

I. INTRODUCTION—

In today's digital world, phishing has become one of the most common and dangerous forms of cyberattacks. According to recent research, "Phishing is one of the most dangerous threats to the world of information and technology. Phishing can be explained as a fraudulent activity in which attackers get (secret) information such as a user's identity, account information (debit or credit card), passcodes, etc." [1] This highlight how phishing attacks are designed to steal sensitive personal information by pretending to be trustworthy entities.

Attacker often pretends to be a trusted organization or someone around, such as a bank, a government department, or a school, and uses special methods to induce the victim to expose his or her own personal information, such as bank passwords, home address, or any other information. phishing has become a major problem in the world because of the variety of methods and the harm it can cause, which can eventually lead to personal property leakage and even more serious consequences.

Attackers employ many variations of sophisticated techniques to lure and trap users. These techniques differ in delivery methods, end states, and targets, with 19 different ways in total according to cybersecurity company Fortinet. This project uses specifically HTTPS phishing, with delivery

methods of email phishing and quishing (using QR codes to phish a victim). This method of phishing is very common in attacks, which is why we crafted the phishing website using these methods. However, due to the ease of making QR codes work for this project, we also included it as quishing is a novel way to phish that is ever increasingly gaining popularity.

Users need to especially take care to protect their data, if they are handling high-sensitivity information, such as banking information, medical information, social security, and national security information, as users with high-value information are usually prime targets for phishing.

We chose to present this topic at Gonzaga University to raise awareness through a hands-on demonstration. Using real-world examples and a fake school password change webpage created by our group, we aimed to help students recognize phishing attempts and understand how they work. In this project, we built a fake Gonzaga password changer, a fake phishing link, a QR code, and a mock email. It is important to emphasize that none of these materials were actually sent out or used maliciously—they were created strictly for classroom use and educational purposes.

The purpose of this project is to raise awareness of the daily precautionary measures, so that students can build a better cybersecurity environment, so as to avoid the leakage of their personal information in some inadvertent places.

II. ETHICAL—

This project is for learning and teaching purposes and has not been sent to anyone, nor has it caused any damage to anyone's information or property. All websites, links, QRs and emails constructed by our group were used for classroom presentations only and were not used for actual phishing.

In addition, we did not collect any real data or information, and all data and content presented in the code and on the website were used for simulation, not stored or recorded, and did not involve any personal privacy. In the demo stage, we

had volunteers from among our peers in the classroom access the website so they may see for themselves the process of being phished. Any and all data collected from these individuals were not vetted to be legitimate data, and were safely deleted afterwards. The website's source code is in a private repository with very exclusive access and will also no longer be hosted after a set time, ensuring that it will not be used maliciously.

Any and all subjects in the demonstration of the phishing website were either members of the working group or enthusiastic volunteers who willingly inputted information (albeit placeholder or otherwise fake information) into the website to be collected. All information collected (explicitly requested to be fake information that cannot be used to actually compromise a user) were stored only temporarily for the sake of demonstrating the logging capabilities, and were deleted afterwards to secure the information, ensuring an ethical experimental process without any non-consenting subjects or compromising any individuals or organizations with our software.

Through our group's demonstration, we hope that students can better understand how phishing websites work and the damage to their information, in order to strengthen students' awareness of network prevention and build network security together.

III. PHISHING SIMULATION DESIGN—

A. Tools and Setup

To build the phishing simulation website, we chose to use the Flask framework as the main webpage builder, and Python to write the back-end logic, including the processing of user requests and data logging. Flask is lightweight and flexible, which makes it suitable for quickly building a fully-functional demo system.

For website deployment, we used the Render platform, which supports free deployment of Flask applications, allowing us to take a locally-built phishing website and make it live as a real, accessible URL. This approach was more stable than a local server and allowed us to use a QR Code generator to convert the link into a QR code that could be scanned during the demo, eliminating the need to re-run the local server each time.

In terms of data logging, we simulated and recorded the account and password information entered by the testers, and saved the information in both CSV and JSON formats to facilitate data reading and analysis at a later stage. Although all the input data is for demonstration purposes and does not involve real user information, we still simulated the whole process of back-end information capture, including submission timestamps, IP addresses, and so on, so as to more realistically restore the attack process of the phishing website.

B. Fake Login Page

In order to make our phishing website more realistic, we first observed and disassembled Gonzaga University's real service webpage, extracted its interface style, color scheme, fonts, page structure, and other visual elements, and integrated these elements into the page we built ourselves. Although forging a domain name was beyond the scope of this project, we still highly recreated the interface of the website itself to make it as close as possible to the real Gonzaga University webpage.

In order to replicate the style of the university's official website, we took real background images from the Gonzaga website and iconic image sources, such as the university logo and login button styles, and applied them to the HTML pages we built. We also designed a moderately transparent background box for the login area, consistent with the original website, to minimize users' visual doubts about the authenticity of the page and thus more effectively simulate the reality of a phishing attack.

In addition, we used the text prompts and button layout similar to the school system to simulate the common service flow of “change password”, so that the testers can easily have a sense of trust when they see the page for the first time. This highly reproducible page design not only improves the effect of phishing simulation, but also helps us better observe whether users will ignore the link address, SSL certificate and other authentication means because of visual trust.

B. Phishing Email

As part of this phishing simulation, we also designed a phishing email whose header, content, and text formatting are modeled after a real school IT security notice. As shown in Figure 1, the title of the email is “URGENT: IT Security Breach”.

This email is designed in the same way as most phishing emails on the web today, by creating panic emails to make users want to quickly confirm or make changes. To enhance the confusion of the email, we refer to several tactics that are commonly used in real phishing attacks:

1. using a sender display name similar to that of the Gonzaga IT department
2. use urgent, panicky wording to create pressure
3. Include links to phishing pages that appear to be legitimate
4. Constructing the attack with elements from the legitimate website to make it look as real as possible

In a more sophisticated environment, this email would contain more advanced methodology, such as using some sort of software or technique to spoof the sender or bypass any email filters or any other countermeasure built in to most modern

day email servers to prevent email phishing. However, due to time and operational constraints, this was not able to be implemented and instead, we have a mockup of what such an email would look like to socially engineer a scenario where a user is successfully convinced or scared into clicking a link.

With this email design, we wanted to test the behavior of users when faced with emotionally-driven scenarios such as “account at risk”, and to demonstrate how phishing attacks often use trust and urgency to manipulate users. (Note that this email was not actually sent to anyone, and was only used as a classroom demonstration to help identify phishing emails.)

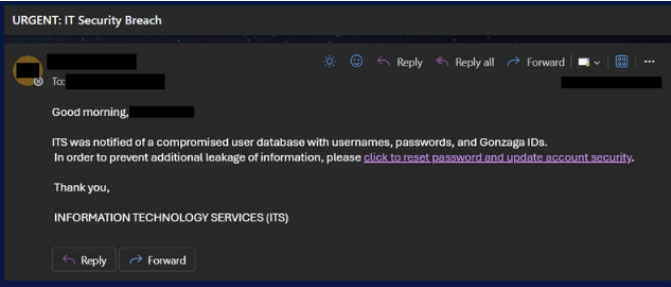


Figure 1: Phishing email

IV. RESULTS—

A. Data logging and collection

We constructed web pages through the Render platform that allowed testers to access our phishing website through a fixed link. We then used a “QR Code Generator” website to generate a QR code based on that link, which testers could scan to quickly access the phishing site. Besides the QR code, a link would also take users to the web page if they were to click on it or paste it into a web browser. In a more sophisticated attack these would be delivered through a

Once the tester enters our site, they are presented with a fake interface similar to the Gonzaga password change page. Once they enter their account number and password, the system records these inputs in JSON and CSV format in the backend database. In addition, besides the basic account and password information, our system also records information about the devices used by the testers (e.g., operating system version, browser type, etc.) as well as the network environment (e.g., hostname and proxy information), as shown in FIGURE 2. These data simulate the common behavior in real phishing attacks—attackers not only steal login credentials, but also analyze the user's device fingerprinting to circumvent the anti-fraud system or carry out subsequent attacks. We again reiterate that none of the data collected is legitimate and will not and cannot be used for any malicious purposes.

Through the design and implementation of this section, we were able to simulate a complete information collection chain

and observe whether users would be careless under the conditions of “high simulation of the interface + QR code entrance”, thus enhancing the practicality and educational value of the project.



Figure 2: Simulated phishing submission log

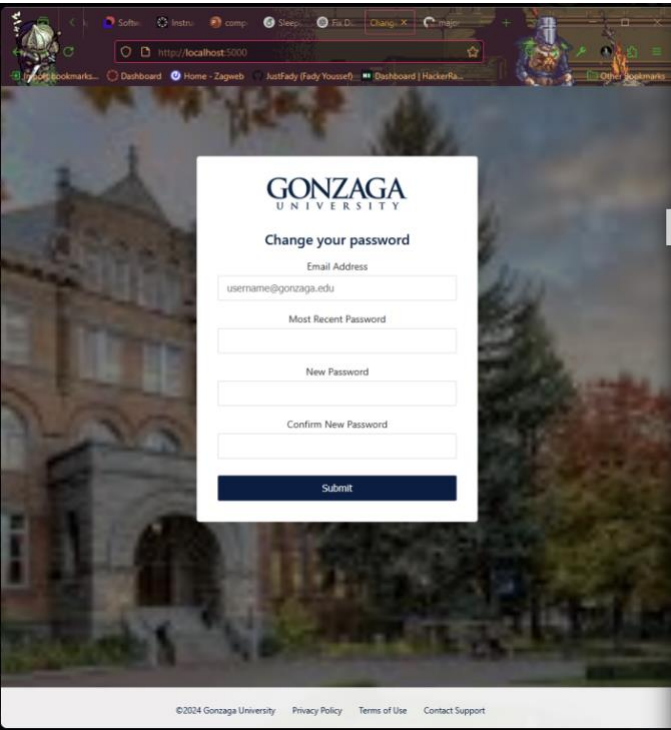


Figure 3: Gonzaga Fake Password Change Website

B. Data Analysis (what this shows)

As shown in Figure 3, we constructed a fake Gonzaga password change page using the background image of the school's official website, the official logo, and common fonts and page layout formats. The purpose of this design was to give the tester the false impression that he/she was visiting a normal school interface.

The purpose of this design was to help us test how the behavior of the testers would change under the influence of visual familiarity and brand trust. The high level of simulation on the page significantly increases the likelihood that users will enter information, which is a core tool that many of

today's phishing sites rely on - using visual similarity to gain trust and data from users. However, if the user takes a closer look, they will notice that firstly, the link is not the same as the real school, and secondly, on the modification page, a regular website will not allow you to enter your account number and password at the same time in a single interface, such as Google, which uses the method of entering the email address first, and then jumping to another page to enter the password.

This design also further emphasizes the importance of learning to recognize suspicious websites in everyday life, as most advanced phishing attacks try to confuse users by appearing as close as possible to the real website they are mimicking.

Additionally, we have found that many phishing websites intentionally include words such as "school certified", "security verified", or even fake trust icons (such as a lock icon or "Verified by XYZ" text) to further create the illusion of 'safe and trustworthy'. Therefore, it is no longer enough to judge whether a web page is authentic based on interface style or branding elements.

C. Lessons and Takeaways

Through this project, we realized that it doesn't take a lot of technical skills and time to build a phishing website. As our project shows, we only use python code as the main back-end tool, and utilize http and css to build the webpage, and then we can quickly create phishing pages with a realistic look and feel.

The key reason for the success of many of these phishing attacks is that people lack the ability to recognize web pages, and can easily trust "familiar-looking" interfaces or brands, thus revealing their personal information. Therefore, this experiment clearly demonstrates the prevalence and efficiency of phishing attacks in today's society, and better illustrates the necessity and importance of raising awareness of cyber security.

In addition, as shown in the fake email in Figure 1, the email usually adopts the same notification and content format as the regular brand or the official one, and adds the message of urgency, account problem, or payment in progress in the content, which further induces the user to click on the attached link or QR code to enter the corresponding website.

We realize then, therefore, the importance of cyber awareness trainings, as to the average user, it is incredibly easy to convince, scare, or otherwise bait a victim to falling for a phishing attack. Ensuring that they are aware of the different methods an attacker will use to steal information and how to identify them and report to their organization's IT department will go a long ways to not only maintain their organization's

operational security, but also to preserve the security of their own private data as well.

V. SUMMARY—

A. Conclusion

In a similar vein to the labs on other Computer Security concepts, such as sniff/spoofing, buffer overflow, and other attacks, working from the perspective of the attacker in order to research and build a phishing attack helped further our understanding regarding how and why people get phished. Over the course of preparing proofs of concepts, drafting, and actually constructing the website, we came to understand the psychological factors that drive victims into being lured by attackers. Studying actual attacks, as well as looking at things from the attacker perspective also helped us through this process. Viewing an attack from an outsider's perspective or even the victim's perspective is one thing but analyzing how one needed to successfully convince or deceive someone into falling for this trap was only really possible by playing the role of the phisher.

The final product was very believable for the layman, who, unless they had been working through their cybersecurity trainings or had knowledge in the cybersecurity field, would most likely have fallen for the trap and given up their sensitive information, which highlights the importance of said trainings to ensure that people can easily identify these sorts of attacks. The fact that it is doable with a reasonable amount of effort by anybody to fabricate a deceptive attack such as the one we have made drives deep the idea that we must be careful at all times on the internet, and learn to critically think before we click links, especially if the context around them is suspicious.

To conclude, our work on this project was incredibly helpful in realizing the effort attackers put in to ensure that their attack methodologies are very convincing to the end user, and as we explored the ways they create these attacks, we became more and more familiar with why people are baited into surrendering information.

B. Future work

In the future, to expand upon this project, there are several avenues of approach to create an improved version of the website for training usage. The current delivery methods for this website are limited to just a free link and a QR code, which, while they are the foundation of a HTTPS phishing attack, would benefit from more sophisticated delivery mechanisms. For example, spoofing an email to come from "Gonzaga ITS Services" with the link, or creating a fake poster with the QR code on it with some social engineering would create an ever-convincing attack mechanism.

Such a convincing example of a phishing attack shouldn't be left to collect virtual dust in a GitHub repository, and instead, should ideally be used. In order to make use of this, rather than use it to conduct an attack, it can be used as a training aid as part of a cyber awareness course to present users a scenario in which they need to identify the various aspects of a phishing attack and understand that these attacks can make very convincing displays that people will easily fall for.

In addition, we can also introduce some other features, such as user feedback mechanism, when the user has successfully entered information, we will automatically pop up an explanation page to provide feedback and educational instructions on whether the user recognizes phishing or not, and secondly, we will incorporate some AI models to recognize the phishing page features and user behaviors, in order to build a combination of offensive and defensive learning environments.

VI. APPENDIX—

GitHub Repository:

The full source code for the phishing website, including the Flask backend, HTML/CSS front-end design, and logging logic, can be accessed here:

[HTTPS://GITHUB.COM/JUSTFADY/GU-PHISHING-AWARENESS.GIT](https://github.com/JustFady/GU-Phishing-Awareness.git)

ACKNOWLEDGMENT

We would like to thank Dr. Yanping Zhang, professor of Computer Security (CPSC 348) at Gonzaga University, for supporting this project and encouraging hands-on learning. We also appreciate the space and freedom to explore real-world cybersecurity ideas through a creative and practical approach.

REFERENCES

- [1] Yasin, Affan et al. "Can Serious Gaming Tactics Bolster Spear-Phishing and Phishing Resilience? : Securing the Human Hacking in Information Security." Information and software technology 170 (2024): 107426-. Web.
- [2] Fortinet et al. "What is Phishing?" <https://www.fortinet.com/resources/cyberglossary/phishing> Web.